

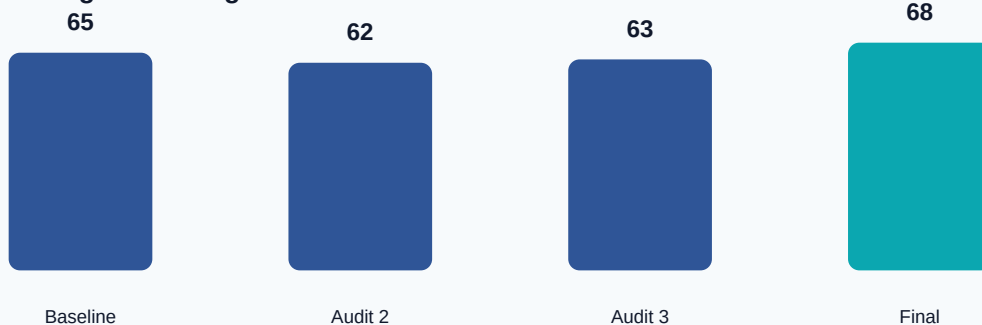


PROJECT DASHBOARD

LINUX SYSTEM HARDENING • LYNIS AUDIT



Hardening Index Progression



Control area	Documented action	Verification
Authentication	Fail2Ban enabled	Active + sshd jail
File integrity	debsums installed/run	Changed/missing files reviewed
Default permissions	UMASK 027	Configuration read back
Unneeded service	ATFTP server removed	Service/package checked
Login banners	/etc/issue + issue.net	Content verified

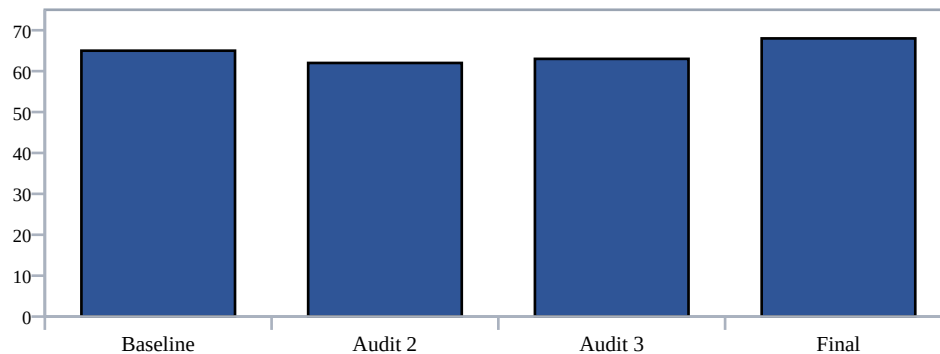


LINUX SYSTEM HARDENING

Lynis-Based Security Audit, Remediation & Verification

Professional Project Report

Lynis hardening index progression



Final hardening index: 68

Baseline: 65 | Final: 68 | Net improvement: +3 points

Assessment platform: Kali Linux virtual machine

Audit tool: Lynis 3.1.6

Assessment approach: audit → analyze → remediate → verify → re-audit



1. Executive Summary

This project assessed and hardened a Kali Linux virtual machine using the Lynis security auditing tool. The work followed a controlled security-hardening cycle: establish a baseline, review Lynis findings, classify recommendations by risk and applicability, apply selected remediations, verify the resulting system state, and perform a final Lynis audit.

The initial documented hardening index was **65**. During the remediation process, the index temporarily fell to **62** and then recovered to **63**. After additional targeted remediation and verification, the final documented index reached **68**. This represents a **3-point improvement over the original baseline** and a 6-point recovery from the lowest observed score.

The temporary decrease was treated as an important verification result rather than as a reason to apply changes blindly. Lynis recalculates its index from the tests and system state detected at each audit; therefore, a configuration change does not automatically translate into a higher score. The captured evidence does not isolate one single cause for the 65→62 change, so the report deliberately avoids claiming an unsupported cause.

The project concentrated on practical hardening measures that were appropriate to the observed Kali environment. Documented actions included tightening the default UMASK, investigating and removing the ATFTP server, installing several security and maintenance utilities, enabling and verifying Fail2Ban, and strengthening the local login warning banners. The remaining Lynis recommendations were reviewed but not all were implemented because several are system-purpose dependent or could unnecessarily disrupt a security-testing workstation.

The final result therefore reflects a **risk-based hardening approach** rather than an attempt to maximize the Lynis number at any cost. The system reached a higher score while preserving the functionality required from a Kali Linux training and security-testing environment.

Key outcomes

Measure	Result
Baseline hardening index	65
Lowest observed index	62
Intermediate verified index	63
Final documented index	68
Net change from baseline	+3 points
Final Lynis tests performed	271
Lynis version	3.1.6



2. Scope and Methodology

The assessment focused on the Linux operating system configuration and security posture visible to Lynis. The objective was to identify hardening opportunities, apply appropriate controls, and demonstrate improvement through repeatable auditing.

Methodology

Phase	Purpose
1. Baseline audit	Run Lynis and record the starting hardening index and findings.
2. Finding analysis	Extract Lynis suggestions from /var/log/lynis-report.dat and inspect detailed test IDs.
3. Risk classification	Separate straightforward remediations from changes requiring system-specific decisions.
4. Remediation	Apply selected configuration, service and security-control changes.
5. Verification	Use systemctl, dpkg, file inspection and Lynis detail commands to verify changes.
6. Re-audit	Run Lynis again and compare the resulting hardening index with the baseline.

Evidence principle: each remediation was verified where possible. For example, Fail2Ban was checked first in an inactive state and later confirmed as enabled and running, while configuration changes such as UMASK and login banners were directly read back from the relevant files.

3. Baseline Assessment

```
kali@kali:~$ sudo grep -i "hardening" /var/log/lynis.log | tail -20
2026-08-18 02:49:42 Hardening: assigned maximum number of hardening points for this item (1). Currently having 170 points (out of 259)
2026-08-18 02:49:42 Hardening: assigned partial number of hardening points (0 of 1). Currently having 170 points (out of 260)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 171 points (out of 261)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 172 points (out of 262)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 173 points (out of 263)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 174 points (out of 264)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (0 of 1). Currently having 174 points (out of 265)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 175 points (out of 266)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (0 of 1). Currently having 175 points (out of 267)
2026-08-18 02:49:43 Hardening: assigned maximum number of hardening points for this item (1). Currently having 176 points (out of 268)
2026-08-18 02:49:43 Checking permissions of /usr/share/lynis/include/tests_hardening
2026-08-18 02:49:43 Action: Performing tests from category: Hardening
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (1 of 3). Currently having 177 points (out of 271)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (2 of 3). Currently having 179 points (out of 274)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (2 of 3). Currently having 181 points (out of 277)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (2 of 3). Currently having 183 points (out of 280)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (2 of 3). Currently having 185 points (out of 283)
2026-08-18 02:49:43 Hardening: assigned partial number of hardening points (1 of 3). Currently having 186 points (out of 286)
2026-08-18 02:49:43 Hardening index : [65] [#####]
2026-08-18 02:49:43 Hardening strength: System has been hardened, but could use additional hardening

kali@kali:~$
```

Figure 1 — Baseline Lynis audit evidence showing a hardening index of 65 and Lynis reporting that the system had been hardened but could use additional hardening.

The baseline audit established a starting point of **65**. The report classified the system as hardened but still capable of additional hardening. This became the reference point for measuring the effect of subsequent changes.

```
suggestion[]=-ACCT-9622|Enable process accounting|++|
suggestion[]=-ACCT-9626|Enable sysstat to collect accounting (disabled)|++|
suggestion[]=-ACCT-9628|Enable auditd to collect audit information|++|
suggestion[]=-FINT-4350|Install a file integrity tool to monitor changes to critical and sensitive files|++|
suggestion[]=-TOOL-5002|Determine if automation tools are present for system management|++|
suggestion[]=-FILE-7524|Consider restricting file permissions|See screen output or log file|text:Use chmod to change file permissions|
suggestion[]=-HOME-9304|Double check the permissions of home directories as some might be not strict enough.|++|
suggestion[]=-KRNL-6000|One or more sysctl values differ from the scan profile and could be tweaked|Change sysctl value or disable test (skip-test=KRNL-6000:< sysctl-key>)|
suggestion[]=-HRDN-7222|Harden compilers like restricting access to root user only|++|
suggestion[]=-HRDN-7230|Harden the system by installing at least one malware scanner, to perform periodic file system scans|Install a tool like rkhunter, chkrootkit, OSSEC, Wazuh|
hardening_index=65

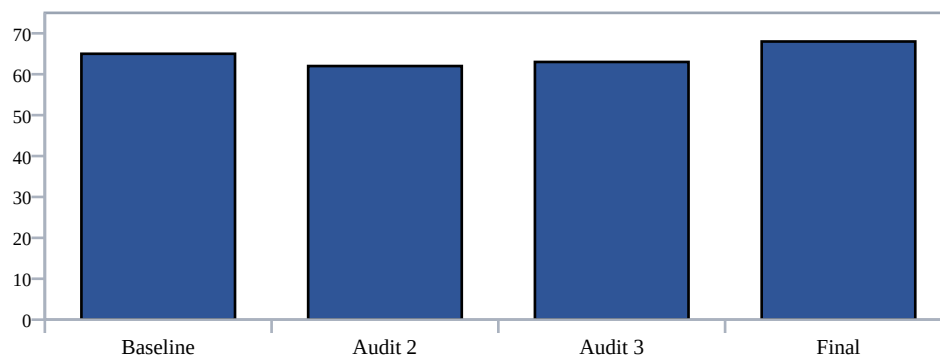
kali@kali:~$
```

Figure 2 — Extracted Lynis suggestions from the baseline report, including accounting, file integrity, permissions, kernel and malware-scanner recommendations.

The initial findings covered multiple categories: boot security, authentication, filesystem layout and permissions, package management, network protocols, web/PHP configuration, logging/accounting, kernel parameters and malware/file-integrity monitoring.

4. Hardening Index Progression

Lynis hardening index progression



Stage	Index	Observed evidence
Baseline	65	Initial Lynis report.
After an intermediate change set	62	269 tests; firewall, intrusion software and malware scanner not recognized in that snapshot.
Next audit	63	269 tests; score recovered by one point.
Final audit	68	271 tests; firewall and intrusion software recognized; final documented score.

```

Details:
Hardening index : 62 [##### ]
Tests performed : 269
Plugins enabled : 1

Software components:
- Firewall [X]
- Intrusion software [X]
- Malware scanner [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer version is available.

Notice: No OS entry was found in the end-of-life database

What to do:
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supported
URL: https://github.com/CISOfy/lynis

Lynis 3.1.6

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)

```

Figure 3 — Intermediate Lynis result: hardening index 62.



```
kali@kali: ~  
Session Actions Edit View Help  
- Compliance status [?] [V]  
- Security audit [V]  
- Vulnerability scan [V]  
  
Details:  
Hardening index : 63 [#####]  
Tests performed : 269  
Plugins enabled : 1  
  
Software components:  
- Firewall [V]  
- Intrusion software [V]  
- Malware scanner [V]  
  
Files:  
- Test and debug information : /var/log/lynis.log  
- Report data : /var/log/lynis-report.dat  
  
Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer version is available.  
  
Notice: No OS entry was found in the end-of-life database  
  
What to do:  
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supported  
URL: https://github.com/CISOfy/lynis  
  
Lynis 3.1.6  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
2007-2025, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)
```

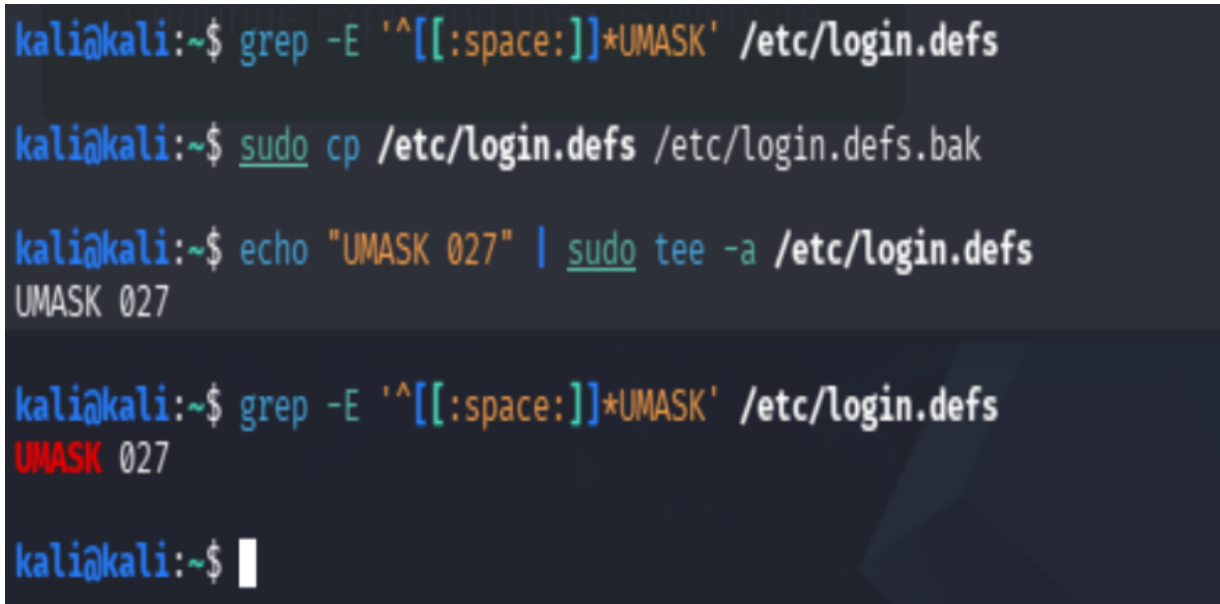
Figure 4 — Subsequent Lynis result: hardening index 63.

Interpretation: The fall from 65 to 62 was not treated as evidence that hardening should stop or that every Lynis recommendation should be applied automatically. The evidence shows that the number of tests also changed during the project. The exact reason for the temporary decrease is not isolated in the captured screenshots, so it is documented transparently rather than guessed.

5. Remediation Activities

5.1 Default UMASK hardening

The login defaults were backed up and a UMASK value of **027** was added to `/etc/login.defs`. A UMASK controls the default permissions assigned to newly created files and directories. A value of 027 reduces default permissions for group and other users compared with a more permissive default.



```
kali@kali:~$ grep -E '^[:space:]*UMASK' /etc/login.defs
kali@kali:~$ sudo cp /etc/login.defs /etc/login.defs.bak
kali@kali:~$ echo "UMASK 027" | sudo tee -a /etc/login.defs
UMASK 027
kali@kali:~$ grep -E '^[:space:]*UMASK' /etc/login.defs
UMASK 027
kali@kali:~$
```

Figure 5 — Backup of `/etc/login.defs` followed by adding UMASK 027 and verifying the resulting entry.

The screenshot demonstrates both the change and the verification step. The backup was created before modification, providing a simple rollback path.

5.2 Removal of the ATFTP server

Lynis identified TFTP-related exposure. The ATFTP service was checked and found inactive. Because an advanced TFTP server was not required for the documented workstation role, the `atftpd` package was removed. The screenshot also shows that the separate `tftp-hpa` client remained installed.

```

kali@kali:~$ dpkg -l | grep -E '^ii\s+(tftp|atftpd)'
ii  atftpd      0.8.1-2          amd64      advanced TFTP server
ii  tftp-hpa    5.4-2            amd64      HPA's tftp client

kali@kali:~$ systemctl status atftpd --no-pager
o atftpd.service - Advanced TFTP Server
   Loaded: loaded (/usr/lib/systemd/system/atftpd.service; indirect; preset: disabled)
   Active: inactive (dead)
 TriggeredBy: o atftpd.socket
   Docs: man:in.tftpd

kali@kali:~$ sudo apt remove atftpd -y
The following packages were automatically installed and are no longer required:
bluez-hcidump  libconfig-inifiles-perl  libllvmspirvlib18.1  librubberband2  libvidstab1.1  python3-aiocache
curlftps       libcrypt-dev             libmbedcrypto16      libstdl2-classic  libxmlsec1-1    python3-aiomcache
enchant-2      libdlt2                  libmupdf25.1         libstrf2          libxmlsec1-openssl1  python3-fs
firmware-marvell-presteria  libfuse2t64           libntfs-3g89t64      libstmp40t64      llvmspirv-18     python3-pluginbase
libabs120260107  libgav1-1               libplacebo351        libsodium23       mesa-va-drivers  python3-pysmp4
libaudio2        libgda138               libpocketsphinx3     libspninxbase3t64  mesa-va-drivers  python3-terminaltables
libavc1394-0     libgdk-pixbuf2.0-bin    libpoppler147        libswscale8       network-manager-gnome  python3-tz
libavfilter10   libhdf5-310             libpoppler156        libteamctl0       openjdk-21-jre     python3-wapiti-arsenic
libavformat61   libhdf5-hl-310          libpostl1            libtsk19t64       openjdk-21-jre-headless  python3-yaswp
libblosc2-4     libio-pty-perl          libpostproc58        libunilibreak6    pocketsphinx-en-us  ruby-unf-ext
libbluray3      libipc-run-perl         libraw23t64          libvdpau-va-gli    postgresql-common-dev  vdpau-driver-all

Use 'sudo apt autoremove' to remove them.

REMOVING:
  atftpd  kali-linux-default  kali-linux-headless

Summary:
  Upgrading: 0, Installing: 0, Removing: 3, Not Upgrading: 84
  Freed space: 211 kB

(Reading database, 447685 files and directories currently installed.)
Removing kali-linux-default (2026.3.2)...
Removing kali-linux-headless (2026.3.2)...
Removing atftpd (0.8.1-2)...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.3.2)...

kali@kali:~$ dpkg -l | grep -E '^ii\s+(atftpd)'

kali@kali:~$ dpkg -l | grep -E '^ii\s+(tftp-hpa)'
ii  tftp-hpa    5.4-2            amd64      HPA's tftp client

kali@kali:~$

```

Figure 6 — ATFTP service investigation and removal of the atftpd package.

5.3 Security and maintenance utilities

Several packages recommended by Lynis were installed and then verified through dpkg. The documented final package state included **apt-listchanges**, **debsums**, **fail2ban**, **libpam-tmpdir** and **needrestart**.



```

Session Actions Edit View Help
- PAM (Pluggable Authentication Modules):
[WARNING]: Test DEB-0001 had a long execution: 37.847999 seconds
- libpam-tmpdir [ Not Installed ]
- File System Checks:
- DM-Crypt, Cryptsetup & Cryptmount:
- Software:
- apt-listbugs [ Installed and enabled for apt ]
- apt-listchanges [ Not Installed ]
- needrestart [ Not Installed ]
- fail2ban [ Not Installed ]
]
[+] Boot and services
- Service Manager [ systemd ]
- Checking UEFI boot [ DISABLED ]
- Checking presence GRUB2 [ FOUND ]
- Checking for password protection [ NONE ]
- Check running services (systemctl) [ DONE ]
  Result: found 21 running services
- Check enabled services at boot (systemctl) [ DONE ]
  Result: found 18 enabled services
- Check startup files (permissions) [ OK ]
- Running 'systemd-analyze security'
  Unit name (exposure value) and predicate
- ModemManager.service (value=6.3) [ MEDIUM ]
- NetworkManager.service (value=7.8) [ EXPOSED ]
- accounts-daemon.service (value=5.5) [ MEDIUM ]
- colord.service (value=3.5) [ PROTECTED ]
- cron.service (value=9.6) [ UNSAFE ]
- cups.service (value=9.6) [ UNSAFE ]
- dbus.service (value=9.3) [ UNSAFE ]
- emergency.service (value=9.5) [ UNSAFE ]
- getty@tty1.service (value=9.6) [ UNSAFE ]
- haveged.service (value=3.2) [ PROTECTED ]
- lightdm.service (value=9.6) [ UNSAFE ]
- lynis.service (value=9.6) [ UNSAFE ]
- open-vm-tools.service (value=9.5) [ UNSAFE ]
- pscsd.service (value=1.8) [ PROTECTED ]
- plymouth-start.service (value=9.5) [ UNSAFE ]

```

Figure 7 — Earlier Lynis audit showing several recommended packages as not installed, including *libpam-tmpdir*, *apt-listchanges*, *needrestart* and *fail2ban*.

These utilities address different aspects of defensive maintenance: package-change awareness, file-integrity verification, authentication-abuse response, safer temporary directories and identification of services that need restarting after library updates.

5.4 Fail2Ban enablement and verification

Fail2Ban was initially observed as disabled and inactive. It was then enabled and started with systemd. The final verification shows the service as **enabled** and **active (running)**, with one configured jail listed: **sshd**.

```
(kali@kali)-[~]
$ sudo systemctl status fail2ban --no-pager
o fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; disabled; preset: disabled)
   Active: inactive (dead)
     Docs: man:fail2ban(1)

(kali@kali)-[~]
$ sudo systemctl enable --now fail2ban
Created symlink '/etc/systemd/system/multi-user.target.wants/fail2ban.service' → '/usr/lib/systemd/system/fail2ban.service'.

(kali@kali)-[~]
$ sudo systemctl status fail2ban --no-pager
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: disabled)
   Active: active (running) since Thu 2026-08-20 05:45:03 EDT; 5s ago
     Invocation: bba400aee38a48fa9b68dd644acac988
       Docs: man:fail2ban(1)
    Main PID: 790876 (fail2ban-server)
      Tasks: 5 (limit: 4404)
    Memory: 15.4M (peak: 15.4M)
       CPU: 245ms
    CGroup: /system.slice/fail2ban.service
            └─790876 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Aug 20 05:45:03 kali systemd[1]: Started fail2ban.service - Fail2Ban Service.
Aug 20 05:45:03 kali fail2ban-server[790876]: Server ready

(kali@kali)-[~]
$ sudo fail2ban-client status
Status
├─ Number of jail:      1
└─ Jail list:  sshd

(kali@kali)-[~]
$
```

Figure 8 — Fail2Ban before/after verification: inactive initially, then enabled and running; the client reports one jail, sshd.

5.5 File-integrity verification with debsums

The debsums utility was executed in silent mode to identify installed package files whose checksums or expected presence differed from package metadata. The captured output reported changed or missing files associated primarily with the Nessus package, plus one documentation file. These findings were treated as integrity observations rather than automatically overwritten, because the files may reflect legitimate application configuration or installation state.

Security interpretation: a debsums mismatch does not by itself prove compromise. It indicates that a package-managed file is different from the recorded checksum or is missing, and therefore merits review.

5.6 Login warning banners

```
(kali@kali)-[~]
$ cat /etc/issue
Authorized users only. All activity may be monitored and reported.

(kali@kali)-[~]
$ cat /etc/issue.net
Authorized users only. All activity may be monitored and reported.

(kali@kali)-[~]
$ sudo lynis show details BANN-7126
2026-08-18 05:40:45 Performing test ID BANN-7126 (Check issue banner file contents)
2026-08-18 05:40:45 Test: Checking file /etc/issue contents for legal key words
2026-08-18 05:40:45 Result: found string 'authori'
2026-08-18 05:40:46 Result: found string 'monitor'
2026-08-18 05:40:46 Result: found string 'report'
2026-08-18 05:40:46 Result: Found only 3 key words (5 or more suggested), to warn unauthorized users and could be increased
2026-08-18 05:40:46 Suggestion: Add a legal banner to /etc/issue, to warn unauthorized users [test:BANN-7126] [details:-] [solution:-]
2026-08-18 05:40:46 Hardening: assigned partial number of hardening points (0 of 1). Currently having 141 points (out of 207)
2026-08-18 05:40:46 ==

(kali@kali)-[~]
$ sudo lynis show details BANN-7130
2026-08-18 05:40:46 Performing test ID BANN-7130 (Check issue.net banner file contents)
2026-08-18 05:40:46 Test: Checking file /etc/issue.net contents for legal key words
2026-08-18 05:40:46 Result: found string 'authori'
2026-08-18 05:40:46 Result: found string 'monitor'
2026-08-18 05:40:46 Result: found string 'report'
2026-08-18 05:40:46 Result: Found only 3 key words, to warn unauthorized users and could be increased
2026-08-18 05:40:46 Suggestion: Add legal banner to /etc/issue.net, to warn unauthorized users [test:BANN-7130] [details:-] [solution:-]
2026-08-18 05:40:46 Hardening: assigned partial number of hardening points (0 of 1). Currently having 141 points (out of 208)
2026-08-18 05:40:46 Security check: file is normal
2026-08-18 05:40:46 Checking permissions of /usr/share/lynis/include/tests_scheduling
2026-08-18 05:40:46 File permissions are OK
2026-08-18 05:40:46 ==

(kali@kali)-[~]
$
```

Figure 9 — Lynis detail for BANN-7126 and BANN-7130 showing that the existing /etc/issue and /etc/issue.net banners contained only three recognized legal key words and were candidates for improvement.

```
(kali@kali)-[~]
$ echo "WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged"
." | sudo tee /etc/issue
WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged.

(kali@kali)-[~]
$ cat /etc/issue
WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged.

(kali@kali)-[~]
$ echo "WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged"
." | sudo tee /etc/issue.net
WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged.

(kali@kali)-[~]
$ cat /etc/issue.net
WARNING: Unauthorized access is prohibited. Authorized users only. All activity may be monitored and reported. Access may be logged.
```

Figure 10 — Updated /etc/issue and /etc/issue.net content with a stronger unauthorized-access warning, followed by direct verification using cat.



The banners were strengthened to clearly state that access is restricted, activity may be monitored/reported, and access may be logged. This provides a clearer warning to unauthorized users and better aligns the files with Lynis' banner checks.

6. Remaining Findings and Risk-Based Decisions

The final audit still reported recommendations. These were not automatically treated as failures. A professional hardening exercise must distinguish between controls that are appropriate for the system and controls that depend on business purpose, architecture, or operational requirements.

Category	Examples observed	Decision
Safe / generally useful	Service-security review, package maintenance, file-integrity checking, selected permission reviews	Prioritize and implement where the control does not disrupt the workstation.
System-purpose dependent	USB/FireWire drivers, GRUB password, password aging, uncommon protocols	Review first; apply only if appropriate to the VM's intended use.
Application-specific	Apache mod_evasive, modsecurity, PHP allow_url_fopen	Not automatically applicable to a Kali workstation simply because Lynis can test for them.
Architecture-dependent	Separate /home or /var partitions, external logging	Requires planning and should not be changed only for a score increase.
Monitoring / advanced hardening	Auditd, sysstat, process accounting, malware scanner, sysctl tuning	Potential future phase; validate resource impact and training requirements first.

```

on files, cron jobs and startup scripts.++
suggestion[]=PKG5-7370|Check debsums configuration and enable checking regularly via a cron job (CRON_CHECK in default file).++
suggestion[]=PKG5-7420|Consider using a tool to automatically apply upgrades++
suggestion[]=NETW-3200|Determine if protocol 'dccp' is really needed on this system++
suggestion[]=NETW-3200|Determine if protocol 'sctp' is really needed on this system++
suggestion[]=NETW-3200|Determine if protocol 'rds' is really needed on this system++
suggestion[]=NETW-3200|Determine if protocol 'tipc' is really needed on this system++
suggestion[]=HTTP-6640|Install Apache mod_evasive to guard webserver against DoS/brute force attempts++
suggestion[]=HTTP-6643|Install Apache modsecurity to guard webserver against web application attacks++
suggestion[]=PHP-2376|Change the allow_url_fopen line to: allow_url_fopen = Off, to disable downloads via PHP++
suggestion[]=LOGG-2154|Enable logging to an external logging host for archiving purposes and additional protection++
suggestion[]=LOGG-2190|Check what deleted files are still in use and why.++
suggestion[]=INSE-8300|Remove rsh client when it is not in use or replace with the more secure SSH package++
suggestion[]=INSE-8318|It is recommended that TFTP be removed, unless there is a specific need for TFTP (such as a boot server)++
suggestion[]=ACCT-9622|Enable process accounting++
suggestion[]=ACCT-9626|Enable sysstat to collect accounting (disabled)++
suggestion[]=ACCT-9628|Enable auditd to collect audit information++
suggestion[]=FINT-4350|Install a file integrity tool to monitor changes to critical and sensitive files++
suggestion[]=TOOL-5002|Determine if automation tools are present for system management++
suggestion[]=FILE-7524|Consider restricting file permissions|See screen output or log file|text:Use chmod to change file permissions|
suggestion[]=HOME-9304|Double check the permissions of home directories as some might be not strict enough.++
suggestion[]=KRNL-6000|One or more sysctl values differ from the scan profile and could be tweaked|Change sysctl value or disable test (s
kip-test=KRNL-6000:<sysctl-key>)|
suggestion[]=HRDN-7222|Harden compilers like restricting access to root user only++
suggestion[]=HRDN-7230|Harden the system by installing at least one malware scanner, to perform periodic file system scans|Install a too
l like rkhunter, chkrootkit, OSSEC, Wazuh|

(kali@kali)-[~]
└─$ sudo grep -E 'hardening|Hardening' /var/log/lynis-report.dat | tail -10
suggestion[]=BOOT-5264|Consider hardening system services|Run '/usr/bin/systemd-analyze security SERVICE' for each service|
hardening_index=68

(kali@kali)-[~]
└─$

```

Figure 11 — Final report still contains selected recommendations, including service hardening, package/debsums checking, network-protocol review, accounting, file integrity, sysctl tuning and malware scanning.

Important: The final project did not install a malware scanner solely to increase the Lynis score. Lynis still reports HRDN-7230 as a recommendation. This is documented as an open hardening opportunity rather than represented as completed work.

7. Final Verification

```

Details:
Hardening index : 68 [##### ]
Tests performed : 271
Plugins enabled : 1

Software components:
- Firewall [V]
- Intrusion software [V]
- Malware scanner [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer version is available.

=====

Notice: No OS entry was found in the end-of-life database

What to do:
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supported
URL: https://github.com/CISOfy/lynis

=====

Lynis 3.1.6

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2025, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)

```

Figure 12 — Final Lynis audit: hardening index 68, 271 tests performed, firewall recognized and intrusion software recognized.

The final audit provides the strongest overall evidence of project outcome. Lynis reports a hardening index of **68** after the documented remediation work. The audit performed 271 tests and recognized both firewall and intrusion software components.

Final state summary

Control / Evidence	Final status
Lynis hardening index	68
Firewall detection	Recognized by Lynis in final audit
Intrusion software	Recognized by Lynis in final audit
Fail2Ban	Enabled and active; sshd jail present
UMASK	UMASK 027 configured in /etc/login.defs
ATFTP server	atftpd removed after service review
Package hardening utilities	apt-listchanges, debsums, fail2ban, libpam-tmpdir and needrestart installed
Login banners	/etc/issue and /etc/issue.net strengthened and verified
Remaining Lynis recommendations	Reviewed; not all applied because applicability and operational impact vary



8. Conclusion

The project successfully demonstrated a repeatable Linux hardening workflow using Lynis. The most important achievement is not simply the final number, but the documented relationship between findings, remediation, verification and re-audit.

Starting from a hardening index of **65**, the project encountered an intermediate reduction to **62**, recovered to **63**, and ultimately reached **68**. The final result is therefore **3 points higher than the original baseline**. The progression also demonstrates why security configuration should be validated after every significant change.

The remediation work addressed several concrete defensive controls: safer default permissions through UMASK 027, removal of an unnecessary TFTP server component, installation of security/maintenance utilities, active Fail2Ban protection for SSH authentication abuse, package-file integrity checking with debsums, and stronger login warning banners.

The remaining Lynis recommendations should be considered a roadmap rather than a list that must be blindly implemented. In particular, malware scanning, auditd/sysstat, sysctl tuning, GRUB protection, partition separation, protocol reduction and application-specific web/PHP hardening should be assessed against the intended role of the Kali VM before implementation.

Final assessment: The system is measurably better hardened than at the start of the documented project, the changes were verified, and the final Lynis result provides objective evidence of improvement.

Recommended next phase: preserve the current 68-point state as a checkpoint, document any additional changes individually, re-run Lynis after each change set, and only implement controls that are justified by the system's intended security role.

Appendix A — Key Commands and Evidence

Purpose	Command / action
Run Lynis audit	<code>sudo lynis audit system</code>
Extract suggestions	<code>sudo grep '^suggestion' /var/log/lynis-report.dat</code>
Inspect a Lynis test	<code>sudo lynis show details TEST-ID</code>
Backup login defaults	<code>sudo cp /etc/login.defs /etc/login.defs.bak</code>
Set UMASK	<code>echo "UMASK 027" sudo tee -a /etc/login.defs</code>
Check UMASK	<code>grep -E '^[[:space:]]*UMASK' /etc/login.defs</code>
Check package state	<code>dpkg -l grep -E 'libpam-tmpdir apt-listchanges needrestart fail2ban debsums'</code>
Enable Fail2Ban	<code>sudo systemctl enable --now fail2ban</code>
Verify Fail2Ban	<code>sudo systemctl status fail2ban --no-pager</code> and <code>sudo fail2ban-client status</code>
Verify package files	<code>sudo debsums -s</code>
Verify final index	<code>sudo grep -E 'hardening Hardening' /var/log/lynis-report.dat tail -10</code>

The command list above is included for reproducibility. The report intentionally focuses on the security reasoning and observed outcomes rather than presenting every terminal line from the full Lynis output.

Appendix B — Screenshot Evidence Index

Figure	Evidence
1	Baseline Lynis hardening index 65
2	Baseline Lynis suggestion extraction
3	Intermediate hardening index 62
4	Intermediate hardening index 63
5	UMASK 027 configuration and verification
6	ATFTP service review and removal
7	Initial package recommendations detected by Lynis
8	Fail2Ban enablement and final status
9	Initial login-banner Lynis findings
10	Updated login banners and verification
11	Remaining final Lynis recommendations
12	Final hardening index 68

All screenshots included in this report were taken from the practical work supplied during the project. They are used as evidence of the observed states and verification steps.

End of report